

# 高性能漏洞扫描框架的研究

刘传水<sup>1</sup>, 孙磊<sup>2</sup>, 朱宇<sup>1</sup>

(1. 华油钢管有限公司, 河北 沧州 062658; 2. 渤海石油装备制造有限公司研究院(数智技术中心), 河北 沧州 062658)

**摘要:** 漏洞扫描是网络安全防护体系中的关键环节, 肩负着提前发现并修复系统漏洞的重任。文章提出了一种多工具整合的漏洞扫描框架, 旨在结合多种扫描工具的优势, 实现高效、全面的漏洞检测。该框架支持即时和定时扫描任务, 可根据用户需求灵活调度扫描作业。通过集成 OWASP ZAP、Acunetix、EZ、Weblogic-scan、Vulmap 等主流工具, 实现对不同类型漏洞的广泛覆盖, 智能调度模块采用基于负载均衡的算法, 确保高效执行扫描任务, 并使用统一的结果处理模块对扫描结果进行整合与分析。实验结果表明, 该框架在漏洞检测的覆盖率和准确性方面均优于单一工具, 同时能够显著减少扫描时间。

**关键词:** 网络安全; 漏洞扫描; Web 安全; 接口调用; 调度算法

中图分类号: TP393 文献标识码: A

文章编号: 1009-3044(2025)19-0100-03

DOI: 10.14004/j.cnki.ckt.2025.0970

开放科学(资源服务) 标识码(OSID):



## 0 引言

在数字化时代, 网络安全的重要性显而易见, 漏洞扫描作为保障网络安全的关键手段, 其重要性也日益凸显。然而, 传统的单一漏洞扫描工具往往存在局限性, 无法全面、高效地检测出所有潜在漏洞<sup>[1]</sup>。为此, 本文提出了一种多工具结合的高性能漏洞扫描方法, 旨在通过整合多种漏洞扫描工具的优势, 实现更全面、更高效的漏洞检测。此方法提升了漏洞检测的覆盖率, 还能通过工具间的互补性提升检测的准确性和效率, 通过调度<sup>[2]</sup>和负载均衡算法<sup>[3]</sup>实现多机扫描, 大大提高扫描效率的同时也规避了网站入侵防御系统对扫描结果的影响。

截至 2022 年 12 月, 我国网民规模增长至 10.67 亿, 互联网普及率达到了 75.6%。在 Web 应用快速扩张的同时, 其在网络攻击、漏洞和恶意代码等方面的安全威胁也在增加。因此, 保障 Web 应用安全工作迫在眉睫。漏洞扫描工具是用于自动检测 Web 应用和系统漏洞的安全测试工具<sup>[4]</sup>。通过模拟黑客攻击, 与 Web 应用程序进行交互。漏洞扫描器可以通过 Web 应用程序的反馈信息来评估目标的安全性, 自动化地扫描、分析、识别并报告其中的安全漏洞, 例如 SQL 注入<sup>[5]</sup>、信息泄露、跨站请求伪造等<sup>[6]</sup>。

漏洞扫描工具一般分为被动式和主动式两种类型。被动式扫描器通常基于代理, 通过监控 Web 应用程序的流量来识别 HTTP 请求和响应中的漏洞; 而主动式扫描器则通过对 Web 应用程序进行主动测试, 如

发送恶意数据包、尝试绕过身份验证等, 来发现安全漏洞。主动式扫描器在检测深度和准确性方面通常更具优势<sup>[7]</sup>。

## 1 方法论

单一工具往往无法全面覆盖所有类型漏洞, 如 OWASP ZAP<sup>[8]</sup>、Acunetix、EZ 等, 它们都属于主动漏洞扫描方法, 且各自具有独特的功能和优势。因此, 整合这些工具以发挥各自优势, 并通过合理调度算法实现大规模漏洞扫描的研究, 成为当前网络安全领域的一个重要课题。

### 1.1 框架设计

本文提出的高性能漏洞扫描框架, 通过调用方法提供的 API 接口实现, 框架通过合理的调度机制来结合多种主流扫描工具的优势, 实现了更全面、高效、精准的漏洞检测, 框架如图 1 所示。

用户交互层为用户提供操作界面, 支持 Web 用户交互界面和命令行交互窗口两种形式。用户可以通过 Web 界面直观地选择扫描任务类型、设置扫描参数、提交扫描任务并查看结果。任务管理层是基于 Celery 框架<sup>[9]</sup>实现的, 负责扫描任务的创建、调度、扫描任务分配和管理, 其中, 任务调度模块根据任务优先级和系统资源状况, 合理安排任务执行顺序。任务执行单元是扫描任务的实际执行者, 负责调用相应的扫描工具对目标进行检测。智能调度模块是框架的核心, 负责优化任务分配与资源利用。结果处理层对扫描结果进行统一处理和分析, 生成最终

收稿日期: 2025-02-22

作者简介: 刘传水(1970—), 男, 河北沧州人, 工程师, 本科, 研究方向为装备制造业信息化工程与数字化转型; 孙磊(1984—), 男, 河北沧州人, 工程师, 本科, 研究方向为网络安全。

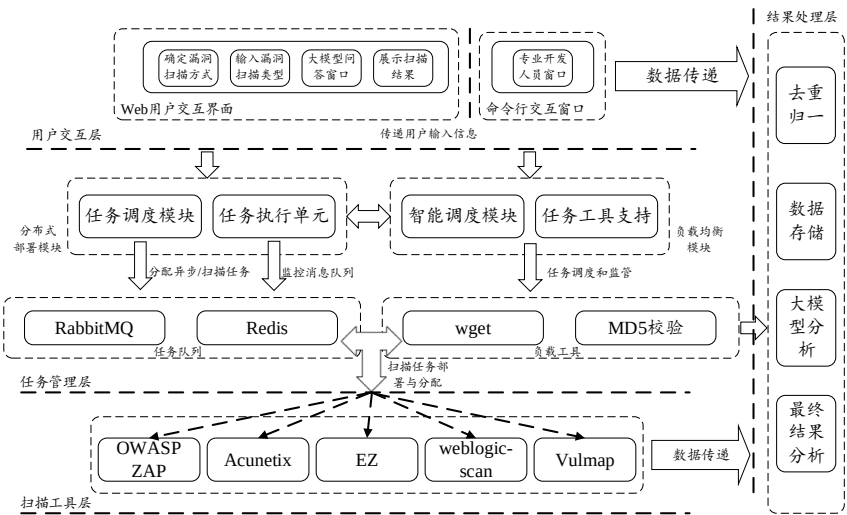


图1 高性能漏洞扫描框架

的漏洞扫描分析报告。整个框架支持分布式部署，可部署在不同服务器上，通过负载均衡机制，合理分配扫描任务到各个执行单元，形成扫描集群，提高并发处理能力。

扫描工具层集成多种主流漏洞扫描工具，包括OWASP ZAP、Acunetix、EZ、Weblogic-scan、Vulmap等。Acunetix能扫描出绝大部分漏洞信息，但是其扫描时间过长，Weblogic扫描速度很快，但这也面临着扫描不全面的问题，OWASP ZAP扫描性能最佳，在保证扫描时间的前提下，也有较好的漏洞扫描效率。

1.2 Web应用扫描方法

Web应用的普及使其安全性成为保护企业数据和用户隐私的关键。Web应用扫描类工具通过自动化的方式检测Web应用中的安全漏洞，下面详细介绍中调研的漏洞扫描方法。

1) OWASP ZAP是开源的漏洞扫描工具。支持多种扫描方式，能够检测Web应用中的各类漏洞，方法本身提供了丰富的API接口，方便与其他工具或系统集成。适用于Web应用开发和测试阶段。

2) Acunetix是一款商业漏洞扫描工具，提供详细的漏洞检测报告生成功能。方法本身具有高度的准确性和易用性，能够检测多种Web漏洞。具有自动化扫描流程，人工干预少、自动生成报告等优点。适用于企业级Web应用安全检测。

3) Vulmap是一款用于检测Web应用中各类漏洞的扫描工具。它支持通过文件或关键词进行批量扫描多个目标，允许用户自定义扫描参数和规则。适用于大规模Web应用。

4) EZ是一款适用于Windows系统的漏洞扫描工具，操作简便，扫描速度快。它能够快速检测Web应用中的常见漏洞。适用于Web应用的快速扫描。

5) Weblogic-scan是一款专注于检测WebLogic服务器漏洞的扫描工具。它能够检测出WebLogic服

器中存在的一些特定漏洞，支持对多个目标进行批量扫描，提高检测效率。适用于使用WebLogic服务器的企业。

2 实验

通过对多个目标URL进行扫描实验，收集并分析了各工具的扫描结果。实验数据表明，整合后的漏洞扫描架构在检测效率和准确性方面均有显著提升。

2.1 实验数据

为了确保实验的全面性和代表性，该研究精心选取了多个具有代表性的目标URL作为实验数据集，如表1所示。

表1 URL测试表

| 网站    | URL                          | 特点                      |
|-------|------------------------------|-------------------------|
| 测试网站1 | http://testhtml5.vulnweb.com | 网站包含多种常见的Web漏洞，适用于综合测试  |
| 测试网站2 | http://testasp.vulnweb.com   | 专注于测试ASP环境下的漏洞          |
| 测试网站3 | http://www.example.com       | 正常运行的网站，测试工具的误报率        |
| 测试网站4 | http://192.168.1.100         | 内部测试服务器，用于测试内网应用的漏洞检测能力 |

2.2 扫描方法和运行流程

漏洞扫描工具的流程如图2所示。

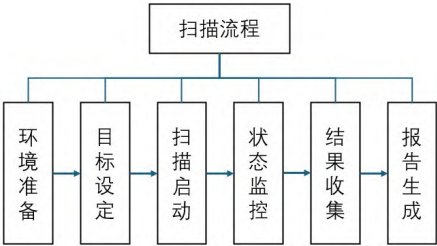


图2 扫描工具流程图

1) 环境准备：根据所选的漏洞扫描工具，下载并安装相应的软件或脚本，确保所有工具都能在最佳状态下运行。OWASP ZAP和Acunetix工具需要在本地或服务器上安装，并配置相关参数。其他工具也分别根据其要求进行了相应参数配置。

2) 目标设定：通过命令行、配置文件或API接口输入要扫描的目标URL或IP地址。并根据扫描需求，定义扫描的目标范围，包括要扫描的端口、服务、应用程序等。

3) 扫描启动：根据目标特点和扫描需求，选择合适的扫描模式并设置扫描的具体参数。例如Acunetix提供的多种扫描模板，如完全扫描、高风险漏洞扫描等。

4) 状态监控:在扫描过程中,监控扫描任务的实时进度,查看扫描完成度、已扫描的 URL 数量等信息。

5) 结果收集:扫描完成后,将扫描结果转换为统一的格式,便于后续的整合和分析。

6) 报告生成:根据收集到的扫描结果生成详细的报告。

7) 结果保存与归档:将扫描结果和报告保存到本地存储设备中,按照一定的目录结构进行分类存储。需要定期对扫描结果进行备份,确保历史数据的完整性和可用性。

2.3 漏洞扫描结果

实验数据以表格和图表的形式直观展示,方便对比分析。如表 2 所示,表中详细列出了不同工具在各个目标下的扫描时间、检测到的漏洞数量等关键指标。

表 2 实验结果

| 方法     | OWASP ZAP                  | Acunetix        | EZ     | Vulmap     | weblogic |
|--------|----------------------------|-----------------|--------|------------|----------|
| 工具类型   | 软件                         | 软件              | exe 文件 | py 脚本      | py 脚本    |
| 是否开源   | 是                          | 否               | 否      | 是          | 是        |
| 是否免费   | 是                          | 否               | 是      | 是          | 是        |
| 目标 URL | http://testphp.vulnweb.com |                 |        |            |          |
| 用时     | 1 h 19 min 12 s            | 3 h 47 min 23 s | 1090 s | 1 min 33 s | 15 s     |
| 扫描漏洞个数 | 22                         | 66              | 40     | 0          | 2        |

OWASP ZAP 具有全面的扫描功能和多种扫描方式,检测到 23 个漏洞,表现较为全面,在目标网站的扫描时间为 1 小时 19 分钟 12 秒,是所有工具中扫描时间较长的工具之一。Acunetix 在相同目标下的扫描时间为 227 分钟 23 秒,长于其他工具。但是,其检测到 66 个漏洞,是所有工具中检测到漏洞数量最多的,体现了其高准确性和全面性。EZ 的扫描时间为 1 090 秒,在所有工具中表现较为高效。检测到 40 个漏洞,数量

较多,通过优化算法和流程,减少了不必要的检测步骤。Vulmap 的扫描时间为 1 分 33 秒,效率较高,但未检测到漏洞。Weblogic-scan 扫描时间为 15 秒,效率高。该工具专注于 WebLogic 服务器相关漏洞的检测,其检测范围相对较窄。

3 结束语

本文提出的漏洞扫描工具整合架构和多方法整合策略,在实验中对对比了不同方法的特点、适用场景和漏洞扫描效果。通过分布式框架和接口调用,利用多台机器进行同时扫描。这样不仅提高了扫描效率,还增强了漏洞检测的全面性。未来,随着新技术的出现和更多先进扫描工具的开发,该架构可进一步优化和扩展,以适应不断变化的网络安全需求,为网络系统的安全防护提供更有力的保障。

参考文献:

[1] 龙华秋,周皓健,燕紫君. Web 漏洞扫描系统的设计与实现[J]. 现代信息科技,2024,8(12):32-35.

[2] 门腾. 分布式网络空间探测系统的设计与实现[D]. 北京:北京邮电大学,2024.

[3] 李子孚. 基于自适应负载均衡的网络安全评估系统研究[D]. 北京:北京邮电大学,2022.

[4] 常会鑫. Web 安全漏洞检测系统设计及优化[D]. 唐山:华北理工大学,2023.

[5] 栗圣森. SQL 注入漏洞与安全防范技术探讨[J]. 轻工科技, 2025,41(2):100-103.

[6] 王保锦,林卉,王健如,等. 跨站请求伪造攻击技术浅析[J]. 网络安全技术与应用,2020(5):28-29.

[7] 刘焯,潘科羽,吕唯因,等. 网络漏洞扫描工具核验方法研究[J]. 现代计算机,2024,30(14):65-69,79.

[8] 秦文生. Kali Linux 在高职信息安全技能教育中的应用[J]. 信息记录材料,2020,21(6):127-129.

[9] 李一风. 基于 Celery 和 Django 的分布式自动化测试系统设计[J]. 信息技术,2019,43(5):97-100.

【通联编辑:闻翔军】

(上接第 99 页)

[9] FENG C,LI T T,CHANA D.Multi-level anomaly detection in industrial control systems via package signatures and LSTM networks[C]//2017 47th Annual IEEE/IFIP International Conference on Dependable Systems and Networks (DSN).Denver,CO, USA.IEEE,2017:261-272.

[10] YANG Q,LIU Y,CHEN T J,et al.Federated machine learning [J].ACM Transactions on Intelligent Systems and Technology, 2019,10(2):1-19.

[11] MOUSTAFA N,SLAY J.UNSW-NB15:a comprehensive data set for network intrusion detection systems (UNSW-NB15 network data set)[C]//2015 Military Communications and Information Systems Conference (MilCIS). Canberra, ACT, Australia. IEEE,2015:1-6.

[12] ARQANE A,BOUTKHOUM O,BOUKHRISS H,et al.A review of intrusion detection systems:datasets and machine learning methods[C]//Proceedings of the 4th International Conference on Networking,Information Systems & Security.KENITRA AA Morocco.ACM,2021:1-6.

[13] SIDDIQUI M K,MORALES-MENENDEZ R,HUANG X D,et al.A review of epileptic seizure detection using machine learning classifiers[J].Brain Informatics,2020,7(1):5.

[14] RUZAFÁ-ALCÁZAR P,FERNÁNDEZ-SAURA P,MÁRMOL-CAMPOS E, et al. Intrusion detection based on privacy-preserving federated learning for the industrial IoT[J]. IEEE Transactions on Industrial Informatics,2023,19(2):1145-1154.

【通联编辑:代影】